

FiHaven — Data Retention & Disposal Policy

Owner	Daniel Hipsskind (FiHaven) — acting Security Officer
Security contact	security@fihaven.app
Version	1.0
Effective date	2026-06-08
Review cadence	Reviewed at least annually and on any material change to data flows or applicable law

This policy is a companion to the [Information Security Policy](#) and operationalizes the retention commitments in FiHaven's public [Privacy Policy](#).

1. Purpose & scope

This policy defines how long FiHaven retains the data it holds, how that data is securely disposed of, and how the policy stays compliant with applicable data-privacy laws (including the EU/UK **GDPR** and the California **CCPA/CPRA**). It applies to all consumer data and operational data across the web, iOS, Android, and backend systems, including data retrieved from Plaid.

2. Principles

- **Retain only as long as necessary** for the purpose it was collected for, or as required by law.

- **Data minimization** — collect and keep the least data needed to operate the Service.
 - **Secure disposal** — when data reaches end of retention (or on a valid deletion request), it is permanently and irreversibly removed.
 - **User control** — users can export their data and delete their account and connected data at any time.
-

3. Retention schedule

Data	Retention	Disposal
Account record (email, display name, password hash)	While the account is open	Permanently deleted on account deletion
Financial data entered by the user (bills, cards, payments, budget, settings)	While the account is open	Permanently deleted on account deletion
Plaid connection (encrypted access token, item, account/balance metadata)	While the bank link is active and the account is open	Permanently deleted on disconnect or account deletion — whichever comes first
MFA secrets (encrypted TOTP seeds, passkey records, backup codes)	While the factor is enrolled	Deleted when the factor is removed or the account is deleted
Login sessions	Until expiry, logout, or revocation	Expired sessions are purged automatically; changing a password revokes a user's other sessions
Single-use email tokens (verify email, password reset, 2FA recovery)	Until used or expired (minutes–24h); stored only as a SHA-256 hash	Invalidated on use/expiry and purged
Subscription reference (Stripe customer/subscription ID or store purchase identifier; status)	While the account is open	Deleted on account deletion (billing records retained by the processor per its own policy)
Security/operational logs (app, PM2, nginx)	Short operational window, then rotated/aged out	Rotated and discarded on a defined cycle; contain no Restricted data

Data	Retention	Disposal
Backups	Aged out on a defined cycle	Old backups are securely destroyed when superseded

FiHaven does **not** store full payment card numbers or bank login credentials at any time (see the Privacy Policy and Information Security Policy §13).

4. Secure disposal

- Records are deleted from the production database; on account deletion the account, sessions, financial data, MFA secrets, and Plaid items/tokens are removed.
 - Encryption-at-rest provides defense in depth: Restricted data (Plaid access tokens, MFA secrets) is stored only in AES-256-GCM-encrypted form, so residual copies are unreadable without the key.
 - Backups containing deleted data are aged out on their cycle; the encryption key is destroyed/rotated when no longer needed for a retained backup.
-

5. Plaid data

Consistent with FiHaven's agreement with Plaid and the Plaid End User Privacy Policy:

- Plaid access tokens and connected-account data are retained **only** while the user maintains the link and the account exists.
- **Disconnecting** an institution in Settings deletes the stored item and its encrypted access token.
- **Deleting the account** removes all Plaid items and tokens.

- Plaid data is used only to display balances to the owning user; it is never sold or shared with third parties.
-

6. User rights

Users can, at any time:

- **Access / export** their data from the app.
- **Correct** their data by editing it directly.
- **Delete** their account and all associated data.

Where applicable law (GDPR/CCPA/CPRA) grants additional rights — access, correction, deletion, restriction, or portability — requests are honored via the security contact above. Identity is verified before acting on a request.

7. Review & enforcement

The Security Officer reviews this policy at least annually and whenever data flows or applicable law change, and verifies that deletion and retention behavior in the Service matches this policy. Exceptions require documented approval, a compensating control, and a remediation date.

Revision history

Version	Date	Change
1.0	2026-06-08	Initial documented data retention & disposal policy.